Axiom Nexus, LLC — Access Controls Policy

Effective date: April 23, 2026 **Owner:** Clarence Fuqua, Founder, Axiom Nexus, LLC **Contact:** security@axiomprotocol.app (monitored group address) · info@axiomprotocol.app (general) **Review cadence:** Annually, or upon any material change to personnel, processor inventory, or applicable law. **Status:** Canonical. This document is the source of truth for the Axiom Nexus access-control program.

This policy is rendered verbatim at `/disclosure/access-controls-policy`. The file at `documents/policies/access-controls-policy.md` is the canonical text. Any change to the policy must change this file; the disclosure page reads it at request time so the document and the page can never drift.

This policy is the operational companion to the Information Security Policy. Where the two overlap, the Information Security Policy is the higher-level statement; this document is the operational specification.

---

1. Purpose and scope

Access control is the primary control surface for protecting consumer financial data. This policy defines:

- Who is allowed to access what.
- How that access is granted, reviewed, and revoked.
- How non-human identities (services, integrations, automated jobs) authenticate.
- The architectural rule that no request is trusted by virtue of network position.

It applies to every system in the Restricted or Confidential data path: production Postgres (Neon), production runtime (Replit Autoscale), production object stores, regulated-rail dashboards (Plaid, Increase, BitGo, Auth0), source control (GitHub), and the operator console of the Platform itself.

2. Identity classes

Class	Examples	Authentication
End user (consumer of the Platform)	Wallet holder, prospective LP, Wealth Practice member	Sign-In With Ethereum (SIWE) backed by a self-custodied wallet. No password is held by the Platform.
Operator (Axiom Nexus personnel with elevated rights inside the Platform)	Compliance reviewer, treasury reviewer, risk operator, super admin	Auth0 session with MFA enforced on the Auth0 tenant. Operator role is authorised at the API layer through `requireOperator(...)` and the policy evaluator.
Personnel (Axiom Nexus personnel with rights to vendor dashboards)	Information Security Lead, Founder	Per-vendor account credentials with MFA enforced on every covered vendor (see §3).
Service (non-human identity invoking an API)	Webhook receiver, scheduled reconciliation job, deployer EOA	Short-lived OAuth tokens, signed JWTs, or signature-verified webhooks over TLS 1.2+. Long-lived shared API keys are prohibited where OAuth or signed-JWT alternatives exist.

3. Multi-factor authentication

MFA is required on every system that stores or processes Restricted or Confidential data and is enforced today on:

- **Replit** (application hosting, secret store, deployment)
- **Neon** (managed Postgres)
- **Increase Dashboard** (banking rail)
- **Plaid Dashboard** (account-verification rail)
- **BitGo Dashboard** (institutional crypto custody)
- **Auth0 Dashboard** (operator identity provider; MFA also enforced on the operator-facing tenant for Platform sign-in)
- **GitHub** (source control)

Personnel without MFA enabled on any covered system have their access to that system revoked.

End users authenticate to the Platform via SIWE; the cryptographic possession of the self-custodied wallet is the second factor on top of any device-level controls the user maintains.

4. Role-based access control

Operator authority is partitioned into deterministic roles enforced at the API layer:

Role	Authority
`SUPER_ADMIN`	Full operator authority, including dual-actor emergency disables. Held only by the Information Security Lead.
`COMPLIANCE_ADMIN`	Eligibility approvals, KYC inspection, sanctions overrides.
`RISK_OPERATOR`	Collateral guardian disable, policy publication.
`AUDITOR_READ_ONLY`	Read-only access to operator data surfaces (asset registry summaries, audit search, user search). No write authority.
`SUPPORT_READ_ONLY`	Limited read-only access for support workflows. Cannot read auditor-only surfaces.

Every state-changing endpoint calls `requireOperator(req, role)` and every decision is funnelled through the deterministic, version-stamped policy evaluator (`lib/capinfra/policy`) so that authorisation is reproducible and auditable. The auditor-only assertion is regression-tested at the endpoint level (see `tests/asset-summary-auth`, `tests/audit-search-auth`, `tests/users-search-auth`).

5. Periodic access reviews

The Information Security Lead conducts a documented access review **quarterly** that covers:

1. Every personnel account on every system in §3.
2. Every operator role assignment in the Platform.
3. Every non-human credential issued from a vendor dashboard (API key, OAuth client, service-account token, signed-JWT issuer).
4. Every secret in the Replit-managed secret store.

Each entry is either reaffirmed (with the business reason recorded) or revoked. The completed review is filed with the Information Security Lead and is producible on request.

6. De-provisioning

When a contributor leaves Axiom Nexus or moves off the Restricted-data path:

- Their access to every system in §3 is revoked within **five business days**.
- Any non-human credential they personally hold (deploy keys, signing keys, machine tokens) is rotated.
- Their operator role assignment in the Platform is removed.
- The action is recorded in the access-review register.

Where a vendor supports SCIM or programmatic de-provisioning the revocation is automated. Where it is not, the revocation is performed manually from the vendor dashboard and the Information Security Lead confirms removal in the next access review.

7. Zero-trust access architecture

The Platform does not maintain a "trusted network" that bypasses authentication or authorisation. Specifically:

- Every request to a Restricted-data endpoint is authenticated regardless of origin.
- Every state-changing financial action is authorised by the policy evaluator regardless of which operator surface invoked it.
- Inbound traffic from regulated processors (Plaid, Increase, Stripe webhook receiver in drain mode, BitGo) is signature-verified before any side effect is taken; the absence of a valid signature causes the request to be rejected without further processing.
- The production runtime does not accept lateral connections from non-production environments; production secrets are never present in non-production environments.

There is no IP allow-list, network position, or shared internal credential that is treated as proof of identity. Identity is always proven cryptographically per request.

8. Non-human authentication

Service-to-service calls in the Restricted-data path authenticate using one of the following:

- **Short-lived OAuth tokens** issued to the service by the calling identity provider.
- **Signed JWTs** with bounded `exp` and audience scoping.
- **Signature-verified webhooks** (HMAC for Stripe-style senders, JWT for Plaid `Plaid-Verification`, Increase-style headers for Increase).
- **Mutual TLS** for the internal preview proxy on Replit Autoscale.

Long-lived shared API keys are restricted to vendors that do not yet support OAuth or signed-JWT authentication. Where they are used, they are scoped to the minimum function, stored only in the Replit-managed secret store, never exposed to the browser, never logged, and rotated on a documented schedule. The current inventory of long-lived keys and the next rotation date for each is maintained by the Information Security Lead.

9. Audit logging

Every privileged action against Restricted or Confidential data is recorded in the append-only `cap_audit_events` table. Each event records the actor (operator id, end-user identity, or service principal), the subject, the timestamp, a correlation identifier, and where applicable the policy decision id and the policy version. Audit events are retained for seven years to satisfy financial record-keeping obligations (see the Data Retention and Disposal Policy).

10. Exceptions and policy review

Exceptions to this policy may only be granted in writing by the Information Security Lead, must be time-bound, and must be accompanied by a compensating control. This policy is reviewed at least annually by the Information Security Lead. Changes are recorded by editing this file in source control; the rendered disclosure page reflects the current text on every load.

Axiom Nexus, LLC operates the Axiom Protocol platform. Security disclosures should be sent to security@axiomprotocol.app (monitored group address). General questions and access requests may be sent to info@axiomprotocol.app.